

AI RISK MANAGEMENT

GOVERNANCE AND SECURITY

Practical Manager and Junior Analyst Manual

What this manual does: Explains how to approve, map, test, secure, monitor, and prove responsible AI use. It covers traditional ML, generative AI, RAG, agents, tools, NIST AI RMF, ISO standards, OWASP risks, CSA AICM, manager decisions, analyst work, and safe labs.

Alberto (Al) Leiva

First Edition • July 2026

Preface

Artificial intelligence can assist people, create content, rank choices, detect patterns, and take actions. It can also be wrong, biased, manipulated, overly powerful, difficult to explain, or used beyond its approved purpose. Good governance helps an organization obtain value while protecting people, information, operations, and trust.

This manual uses plain language and focuses on practical work. It is not legal advice, a certification guide, or a promise that a system is safe. Laws, standards, model behavior, threats, and provider features change quickly. Confirm current authoritative sources and involve qualified legal, privacy, security, data science, human-rights, safety, procurement, audit, and business professionals for real decisions.

Current-information note: Verified July 14, 2026. NIST AI RMF 1.0 remains the published framework but NIST states it is being revised. NIST AI 600-1 remains the Generative AI Profile. CSA AICM v1.1 was released in June 2026. EU AI Act obligations apply progressively, and proposed timing changes are not final law unless adopted; verify status with official sources and counsel.

How to use this manual

- Managers: start with Chapters 1–10, 22–28, then use the decision records in Chapter 30.
- Junior analysts: study in order, run only authorized labs, and build the portfolio in Chapter 29.
- Developers and data teams: focus on Chapters 10–23 and the testing tools in Chapter 26.
- GRC, privacy, legal, and audit teams: focus on Chapters 2–9 and 20–25.
- Record the exact system, model, version, data, use, users, geography, impact, evidence, limitations, and decision for every assessment.

Table of Contents

This file contains a true native Word table of contents plus a permanent page-numbered chapter guide.

Preface	2
How to use this manual.....	2
Table of Contents	3
Chapter Guide	7
1. AI Foundations and Trustworthy Use.....	8
1.1 Trustworthy characteristics	8
2. Governance, Standards, and Legal Landscape.....	9
2.1 Legal and obligation register	9
3. NIST AI RMF Core.....	10
4. GOVERN: Culture, Accountability, and Policy	11
4.1 Governance structure.....	11
5. MAP: Context, People, and Impact	12
5.1 Context record	12
6. MEASURE: Testing and Risk Analysis	13
6.1 Measurement plan	13
7. MANAGE: Treatment, Deployment, and Improvement	14
7.1 Deployment gate.....	14
8. NIST Generative AI Profile.....	15
9. ISO/IEC 42001 and ISO/IEC 23894.....	16
9.1 Certification and copyright cautions.....	16
10. AI Inventory, Use Cases, and Life Cycle.....	17
10.1 Life-cycle controls.....	17
11. Data Governance and Data Security	18
11.1 Data control chain.....	18
12. Model Governance and Model Risk	19
12.1 Validation questions.....	19
13. Foundation Models and Third Parties	20
13.1 Concentration and value-chain risk.....	20
14. AI Security Threat Modeling	21
14.1 Threat-model method.....	21
15. OWASP Top 10 for LLM Applications 2025.....	22

15.1 How an analyst uses the list.....	22
16. Agentic AI Security	23
17. Retrieval-Augmented Generation Security	24
17.1 RAG controls.....	24
18. Prompt, Interface, and Output Security.....	25
18.1 Output handling examples	25
19. Identity, Tools, APIs, and MCP	26
19.1 MCP security.....	26
20. Privacy, Intellectual Property, and Records	27
20.1 Privacy and records assessment.....	27
20.2 Intellectual property	27
21. Fairness, Transparency, Explainability, and Human Oversight.....	28
21.1 Avoid common mistakes.....	28
22. Evaluation, Red Teaming, and Acceptance.....	29
22.1 Red-team rules of engagement	29
23. Monitoring, Incidents, Change, and Retirement.....	30
23.1 AI incident response	30
24. Assurance, Evidence, Testing, and Metrics.....	31
24.1 Control test method	31
25. CSA AI Controls Matrix v1.1	32
25.1 Practical use	32
26. Open-Source AI Assurance and Security Tools	33
26.1 Garak.....	33
26.2 Promptfoo.....	33
26.3 Giskard	34
26.4 PyRIT	34
26.5 Inspect AI.....	34
26.6 Adversarial Robustness Toolbox	34
26.7 LLM Guard	34
26.8 Presidio	35
26.9 Guardrails AI	35
26.10 OpenAI Evals.....	35
26.11 Langfuse	35
26.12 MLflow.....	35

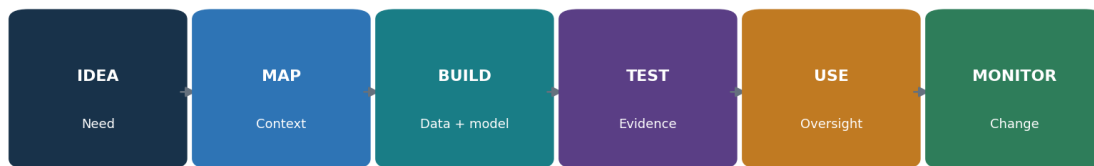
26.13 Evidently	36
26.14 Deepchecks	36
26.15 ModelScan	36
26.16 Gitleaks	36
26.17 Trivy	37
26.18 MITRE ATLAS	37
27. Manager's AI Governance Playbook	38
27.1 Operating rhythm	38
27.2 Questions leaders must answer	38
28. Junior AI Risk and Security Analyst Career Guide	39
28.1 Entry-level roles	39
28.2 Daily work	39
28.3 Resume evidence	40
29. Fictional Laboratory, Thirty-Day Plan, and Interviews	41
29.1 Portfolio lab	41
29.2 Thirty-day plan	41
29.3 What is the NIST AI RMF?	42
29.4 Model risk versus system risk?	42
29.5 What is prompt injection?	42
29.6 How do you evaluate an LLM?	42
29.7 What is RAG?	42
29.8 Why is human oversight difficult?	42
29.9 What is an AI inventory?	42
29.10 How do tools prove compliance?	42
29.11 How do you report a finding?	42
29.12 What makes a good junior analyst?	42
30. Templates, Glossary, Index, and References	43
30.1 AI use-case inventory	43
30.2 AI impact and risk assessment	43
30.3 AI evaluation workpaper	43
30.4 AI incident and change record	43
30.5 Glossary	44
30.6 Subject index	44
30.7 Official references	45

Chapter Guide

Chapter	Title	Starts on page
1	AI Foundations and Trustworthy Use	5
2	Governance, Standards, and Legal Landscape	6
3	NIST AI RMF Core	7
4	GOVERN: Culture, Accountability, and Policy	8
5	MAP: Context, People, and Impact	10
6	MEASURE: Testing and Risk Analysis	12
7	MANAGE: Treatment, Deployment, and Improvement	13
8	NIST Generative AI Profile	14
9	ISO/IEC 42001 and ISO/IEC 23894	15
10	AI Inventory, Use Cases, and Life Cycle	16
11	Data Governance and Data Security	17
12	Model Governance and Model Risk	18
13	Foundation Models and Third Parties	19
14	AI Security Threat Modeling	20
15	OWASP Top 10 for LLM Applications 2025	21
16	Agentic AI Security	22
17	Retrieval-Augmented Generation Security	23
18	Prompt, Interface, and Output Security	24
19	Identity, Tools, APIs, and MCP	25
20	Privacy, Intellectual Property, and Records	26
21	Fairness, Transparency, Explainability, and Human Oversight	27
22	Evaluation, Red Teaming, and Acceptance	28
23	Monitoring, Incidents, Change, and Retirement	29
24	Assurance, Evidence, Testing, and Metrics	31
25	CSA AI Controls Matrix v1.1	32
26	Open-Source AI Assurance and Security Tools	33
27	Manager's AI Governance Playbook	39
28	Junior AI Risk and Security Analyst Career Guide	40
29	Fictional Laboratory, Thirty-Day Plan, and Interviews	42
30	Templates, Glossary, Index, and References	45

1. AI Foundations and Trustworthy Use

Trustworthy AI depends on the complete system, its people, purpose, data, model, interfaces, controls, and real-world effects.



AI risk management follows the system from idea through retirement

Figure 1. AI system life cycle

Concept	Plain meaning	Analyst question
AI system	People, data, models, software, infrastructure, rules, and processes used for an outcome	What is the complete boundary?
Machine learning	Software learns patterns from data rather than only fixed rules	What data and metric support the behavior?
Generative AI	A model produces text, images, audio, video, code, or other content	What can be invented, leaked, or abused?
Agentic AI	A system plans and uses tools to pursue goals with some autonomy	What authority can it exercise?
Trustworthiness	Evidence that characteristics such as validity, safety, security, privacy, fairness, transparency, and accountability are addressed	What claim, threshold, test, and owner support it?

1.1 Trustworthy characteristics

- Valid and reliable: works for the defined purpose and conditions.
- Safe: unacceptable physical, financial, legal, emotional, or operational harm is prevented or reduced.
- Secure and resilient: resists attack, misuse, failure, and disruption and can recover.
- Accountable and transparent: decisions, owners, limits, and evidence can be examined.
- Explainable and interpretable: people receive useful reasons appropriate to the decision.
- Privacy-enhanced and fair: data and outcomes are handled lawfully and harmful bias is evaluated.

2. Governance, Standards, and Legal Landscape

Governance connects voluntary frameworks, management systems, technical practices, contracts, and applicable law.

Source	Use	Important limit
NIST AI RMF 1.0	Voluntary risk framework organized as Govern, Map, Measure, Manage	Published 2023; NIST says revision is underway
NIST AI 600-1	Generative AI risk profile and actions	A profile, not a certification
ISO/IEC 42001:2023	AI management system requirements	Copyrighted standard; certification scope matters
ISO/IEC 23894:2023	AI risk management guidance	Tailor to organization and context
EU AI Act	Risk-based legal duties for covered roles and uses	Application is phased; facts and current law control
OWASP / MITRE ATLAS	Security risks, techniques, defenses, and testing ideas	Not a full compliance program
CSA AICM v1.1	AI control objectives and assurance mapping	Use current artifact and applicable scope

2.1 Legal and obligation register

- Identify jurisdictions, sectors, customers, contracts, employment rules, consumer duties, privacy law, intellectual property, records, accessibility, discrimination, product safety, and cybersecurity requirements.
- Classify organizational role: provider/developer, deployer/operator, importer, distributor, user, data controller/processor, or another role defined by law or contract.
- Record the exact use, affected people, prohibited or high-impact features, notice, consent or other authority, human review, rights, reporting, retention, and supplier duties.
- Treat regulatory summaries as screening aids. Obtain qualified advice for applicability and deadlines.

3. NIST AI RMF Core

The NIST AI RMF Core uses four connected functions to manage AI risks to people, organizations, and society.



NIST AI RMF functions work continuously, not as a one-time checklist

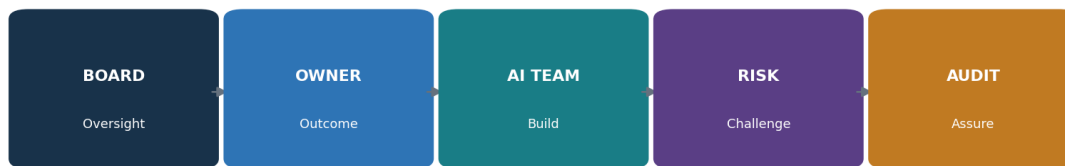
Figure 2. NIST AI RMF Core

Function	Purpose	Typical evidence
GOVERN	Policies, roles, culture, accountability, risk tolerance, suppliers, and continuous improvement	Charter, policy, RACI, training, inventory, exceptions, minutes
MAP	Purpose, context, people, impacts, dependencies, and risks	System map, use case, stakeholders, impact assessment, threat model
MEASURE	Methods, tests, metrics, uncertainty, limitations, and independent review	Test plan, datasets, results, confidence, red-team report, validation
MANAGE	Prioritize, treat, accept, deploy, monitor, respond, and retire	Risk register, approvals, conditions, monitoring, incident/change/retirement records

Do not use the RMF as a checkbox: A category or subcategory becomes useful only after it is tied to an owned system, risk, action, evidence, result, decision, and review date.

4. GOVERN: Culture, Accountability, and Policy

GOVERN establishes who may decide, what rules apply, and how concerns reach accountable leaders.



Clear decision rights prevent accountability gaps

Figure 3. AI governance roles

4.1 Governance structure

- Board or governing body: oversee material risk and management performance.
- Executive sponsor: set direction, resources, risk appetite, and escalation.
- Business owner: own purpose, benefit, affected process, human oversight, and outcome.
- AI/model owner: own model selection, configuration, evaluation, versions, and limitations.
- Data owner: authorize sources, quality, access, use, retention, and deletion.
- Security, privacy, legal, compliance, safety, HR, procurement, accessibility, and domain experts: review their risks.
- Independent risk or validation: challenge evidence and decisions at a level matched to impact.
- Internal audit: independently assess governance and control operation without becoming the owner.

Policy area	Minimum decision
Acceptable use	Approved, restricted, and prohibited uses and data
Risk tiering	Impact factors, thresholds, required reviews, and authority
Development/acquisition	Secure life cycle, supplier evidence, testing, approval, and change
Human oversight	Reviewer competence, authority, workload, information, override, and escalation
Exceptions	Risk, compensating controls, approver, expiry, monitoring, and closure
Concerns	Speak-up, non-retaliation, investigation, protection, and reporting

5. MAP: Context, People, and Impact

MAP turns a model description into an understandable picture of purpose, people, context, and impact.



Assess the complete sociotechnical system—not only the model

Figure 4. Complete AI system map

5.1 Context record

- Business need, intended benefit, success measure, owner, users, and prohibited uses.
- Affected people and communities, including people who may never interact directly with the system.
- Decision or content produced, degree of automation, consequences, alternatives, contestability, and human authority.
- Data sources, lineage, rights, representativeness, sensitive attributes, proxies, and quality.
- Model, provider, version, configuration, prompts, retrieval, fine-tuning, tools, integrations, infrastructure, and dependencies.
- Deployment conditions, geography, language, accessibility, culture, time sensitivity, scale, and reasonably foreseeable misuse.
- Failure modes, threat actors, harms, benefits, uncertainty, existing controls, and monitoring.

Impact factor	Lower concern example	Higher concern example
Decision	Drafting internal text	Eligibility, employment, credit, care, safety, or legal decision
People	Trained staff with review	Public or vulnerable people with limited choice
Autonomy	Suggestion only	Acts through accounts, money, systems, or physical devices
Scale	Small reversible pilot	Large, persistent, difficult-to-reverse effect
Data	Synthetic or public	Sensitive, biometric, confidential, or children's data
Transparency	Clearly disclosed and contestable	Hidden use or weak appeal
Failure	Minor inconvenience	Material financial, health, rights, security, or safety harm

6. MEASURE: Testing and Risk Analysis

MEASURE creates credible evidence about performance, harm, misuse, security, privacy, and uncertainty.

6.1 Measurement plan

- Translate each important risk into a testable claim and acceptance threshold before seeing the result.
- Use representative, protected, versioned evaluation data with documented provenance, exclusions, and known gaps.
- Test normal, edge, subgroup, multilingual, accessibility, adversarial, high-impact, and safe-failure cases.
- Separate development, validation, and final acceptance data where practical to reduce overfitting.
- Measure both benefits and harms; averages can hide severe failures for a subgroup or rare event.
- Record model/system version, prompt, tools, data, environment, scorer, human rubric, sample, randomness, cost, result, confidence, and limitations.
- Use independent review when impact, uncertainty, conflict of interest, or external reliance is high.

Measure	Question	Example evidence
Task quality	Does it do the intended task?	Accuracy, groundedness, error severity, human rating
Safety	Does it avoid unacceptable harm?	Scenario tests, refusals, escalation, hazard analysis
Security	Can an attacker manipulate or extract value?	Threat model, injection tests, tool-abuse tests, red-team report
Fairness	Do errors or treatment differ meaningfully?	Subgroup results, intersectional review, causal/context analysis
Privacy	Can data be exposed, inferred, retained, or misused?	DPIA, leakage tests, access/retention/deletion evidence
Resilience	Does it fail safely under change or outage?	Load, drift, dependency, rollback, recovery tests

7. MANAGE: Treatment, Deployment, and Improvement

MANAGE converts measured risk into an owned decision, a treatment, deployment conditions, monitoring, and improvement.

Treatment	When useful	Required record
Avoid	Use is prohibited or risk cannot be justified	Decision, affected scope, alternatives, enforcement
Reduce	Controls can lower likelihood or impact	Control, owner, due date, residual risk, test
Transfer/share	Contract or insurance allocates part of consequence	Exact allocation, exclusions, dependency, remaining risk
Accept	Residual risk is within authority and appetite	Rationale, evidence, approver, conditions, expiry, monitoring
Pilot	Uncertainty can be reduced safely	Limited people/data/authority/time, stop rule, measurement, exit

7.1 Deployment gate

- Required reviews are complete and unresolved findings are within authorized tolerance.
- Acceptance thresholds are met on the production-like complete system, not only the base model.
- Users understand purpose, limits, prohibited uses, verification duties, and escalation.
- Human reviewers have time, skill, information, authority, and a usable override.
- Security, privacy, supplier, logging, incident, continuity, rollback, record, and deletion controls are ready.
- Monitoring has owners, thresholds, alerts, response playbooks, change triggers, and retirement criteria.

8. NIST Generative AI Profile

NIST AI 600-1 adapts the AI RMF to risks that are especially important for generative AI.

Risk theme	Practical meaning	Example treatment
Confabulation	Plausible output may be false	Grounding, citations, verification, uncertainty, limited decision use
Dangerous or hateful content	Output may facilitate harm or abuse	Use limits, classifiers, policy, review, monitoring, reporting
Data privacy	Sensitive information may enter or leave the system	Minimization, redaction, access, retention, deletion, leakage tests
Information integrity	Synthetic content may mislead or distort ecosystems	Disclosure, provenance, verification, rate limits, response
Information security	Attackers may inject, steal, evade, or exploit	Threat modeling, isolation, least privilege, secure output handling
Intellectual property	Training, input, or output may create rights issues	Provenance, terms, licenses, review, records, dispute process
Environmental impacts	Training and use consume resources	Measure energy/compute where material; set efficiency and use controls
Human-AI configuration	Automation bias or emotional reliance may cause harm	Interface design, literacy, human review, escalation, wellbeing safeguards
Value chain	Risk travels through data, model, platform, integrator, and user	Supplier mapping, contracts, evidence, change notice, shared incidents

Profile use: Select the relevant risks and actions for the actual use case. Do not claim every generative AI risk is solved because a general-purpose provider offers safeguards.

9. ISO/IEC 42001 and ISO/IEC 23894

ISO/IEC 42001 provides an AI management system; ISO/IEC 23894 provides AI risk management guidance.

Management-system element	Practical output
Context	Interested parties, obligations, AI scope, processes, dependencies
Leadership	Policy, accountability, roles, resources, risk direction
Planning	Risks, opportunities, objectives, actions, change planning
Support	Competence, awareness, communication, documented information
Operation	AI risk process, impact assessment, life-cycle controls, suppliers
Performance evaluation	Monitoring, measurement, internal audit, management review
Improvement	Nonconformity, corrective action, continual improvement

9.1 Certification and copyright cautions

- Use an authorized copy of ISO standards; this manual does not reproduce their requirement or control text.
- Define the AI management system scope precisely: organization, products, services, locations, technologies, and exclusions.
- A certificate supports only the named organization, scope, standard, dates, and certification status.
- Certification does not prove every AI output is accurate, fair, secure, lawful, or safe.
- Map existing security, privacy, quality, risk, supplier, and audit processes to avoid parallel paperwork.

10. AI Inventory, Use Cases, and Life Cycle

An accurate inventory and controlled life cycle are the foundation of governance.



A use-case gate matches oversight and evidence to risk

Figure 5. AI use-case gate

Inventory field	What to record
Identity	System/use-case name, ID, owner, sponsor, team, status
Purpose	Intended use, users, affected people, decisions, benefit, prohibited use
Technology	Model/provider/version, prompts, RAG, agents, tools, APIs, hosting
Data	Sources, owners, sensitivity, rights, location, retention, training use
Impact	Risk tier, harms, laws, contracts, assessments, human oversight
Evidence	Evaluation, security, privacy, supplier, accessibility, approval
Operations	Monitoring, incidents, changes, dependencies, recovery, retirement

10.1 Life-cycle controls

- Intake and screen before acquisition, experimentation with real data, or public use.
- Design system and data maps, impact and threat assessments, requirements, acceptance thresholds, and rollback.
- Build with version control, protected environments, approved components, lineage, testing, and review.
- Validate the complete system independently enough for its impact and uncertainty.
- Approve with recorded conditions; deploy through change control; train users and reviewers.
- Monitor quality, security, safety, privacy, fairness, cost, use, suppliers, and incidents.
- Reassess material changes; retire access, integrations, data, artifacts, accounts, and records safely.

11. Data Governance and Data Security

Data controls determine what an AI system can learn, expose, reproduce, or unfairly emphasize.

11.1 Data control chain

- Purpose and authority: why each source is needed and what rights, notices, permissions, or licenses allow use.
- Provenance and lineage: source, collection method, date, version, transformations, labels, filters, and downstream uses.
- Quality and representativeness: completeness, accuracy, timeliness, duplicates, imbalance, label error, historical bias, and relevant populations.
- Security: classification, least privilege, separation, encryption, secrets, secure transfer, monitoring, backup, and deletion.
- Privacy: minimization, pseudonymization/de-identification, re-identification risk, data-subject rights, retention, transfer, and privacy-enhancing techniques.
- Poisoning defense: trusted sources, contributor controls, validation, anomaly review, signed/versioned datasets, quarantine, and rollback.
- Evaluation protection: prevent test-set leakage and preserve a controlled final acceptance set.

Evidence	Minimum detail
Dataset card	Purpose, source, people/populations, collection, fields, labels, exclusions, limits, license
Lineage record	Source-to-feature transformations, code/version, owner, approvals, dates
Quality report	Rules, population, exceptions, subgroup analysis, corrections, limitations
Access report	Users/services, roles, grants, reviews, removals, privileged activity
Deletion test	Request, systems/copies/indexes/backups, method, result, residual limits

12. Model Governance and Model Risk

Model governance controls selection, documentation, validation, change, deployment, and retirement.

Artifact	Purpose
Model/system card	Intended use, prohibited use, architecture, data, performance, limitations, ethics/safety/security
Version record	Model, weights, provider release, configuration, prompt, adapters, tools, code, environment
Validation report	Independence, methods, data, thresholds, results, failures, limitations, decision
Risk tier	Impact factors, required reviews, decision authority, monitoring
Change record	Reason, affected components, regression scope, approval, rollout, rollback
Retirement record	Replacement, users, integrations, access, artifacts, data, retention, deletion, residual duties

12.1 Validation questions

- Is the use within the model's demonstrated and approved conditions?
- Are data and evaluation populations relevant to production?
- Are thresholds tied to business harm instead of only technical averages?
- Does the complete application add prompts, retrieval, tools, post-processing, or human behavior that changes risk?
- Are uncertainty and limitations visible to decision makers and users?
- Can a prior version be restored and can dependent decisions be traced to the active version?

13. Foundation Models and Third Parties

A foundation-model provider supplies one layer; the deploying organization still owns its use, integrations, data, and effects.

Supplier evidence	Review question
System/model documentation	Exact model/version, intended/forbidden use, capabilities, limits, evaluation
Security assurance	Scope, period, testing, vulnerabilities, incident process, tenant isolation
Data terms	Prompt/upload/output/log/feedback use, training, retention, deletion, location, subprocessors
Change management	Notice, version pinning, deprecation, regression evidence, rollback
Availability/resilience	Dependencies, limits, support, recovery, continuity, export
Legal/IP	Roles, licenses, indemnity, restrictions, transparency, regulatory support
Audit/evidence	Reports, logs, customer configuration, access, incident and deletion evidence
Exit	Data/model/configuration export, migration, account closure, verified deletion

13.1 Concentration and value-chain risk

- Map model, cloud, data, labeling, embeddings, vector database, orchestration, tools, content moderation, monitoring, and human-service suppliers.
- Identify common dependencies that could fail or change together.
- Test contractual responsibility against the technical architecture.
- Maintain alternatives or a controlled shutdown where the business impact justifies it.
- Reassess provider changes, new training terms, model retirement, acquisitions, incidents, sanctions, and subprocessor changes.

14. AI Security Threat Modeling

Threat modeling identifies assets, trust boundaries, attackers, abuse paths, controls, detections, and safe recovery.

14.1 Threat-model method

- Draw users, admins, services, model endpoints, data stores, indexes, prompts, tools, networks, logs, providers, and human reviewers.
- Mark assets: sensitive data, model weights, system prompts, credentials, decisions, money, accounts, reputation, and safety.
- Mark trust boundaries and every place untrusted content can become instructions or actions.
- Describe threat actors, access, goals, preconditions, attack path, business impact, evidence, and recovery.
- Map relevant MITRE ATLAS and OWASP techniques, but add domain-specific misuse and ordinary application threats.
- Choose preventive, detective, responsive, and recovery controls; test combinations and bypasses.
- Update after model, data, prompt, tool, provider, permission, interface, or use change.

Threat surface	Examples
Input	Direct prompt injection, malicious files, hidden text, image/audio instructions
Context	Poisoned RAG documents, cross-tenant retrieval, stale or unauthorized sources
Model	Extraction, inversion, evasion, poisoning, unsafe capability, denial of service
Output	XSS, SQL/command injection, insecure code, harmful advice, false claims
Tools/agents	Privilege abuse, confused deputy, transaction fraud, loops, lateral movement
Operations	Weak logs, shadow use, leaked keys, unsafe updates, poor incident rollback

15. OWASP Top 10 for LLM Applications 2025

The OWASP 2025 list is a practical starting point for generative-AI application security.

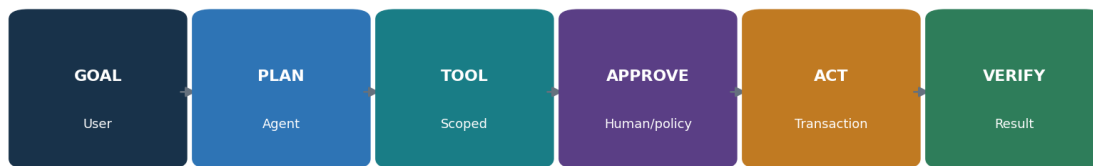
ID / risk	What can happen	Core protections
LLM01 — Prompt Injection	Untrusted instructions change model behavior or reach connected tools.	Separate trust zones; constrain tools; filter context; validate actions; test direct and indirect injection.
LLM02 — Sensitive Information Disclosure	Prompts, outputs, logs, training data, or connectors reveal protected information.	Minimize data; classify; redact; control access; set retention; test leakage; monitor.
LLM03 — Supply Chain	Models, data, packages, adapters, services, or artifacts are compromised or untrusted.	Approve sources; verify provenance, signatures, hashes, licenses, vulnerabilities, and change notices.
LLM04 — Data and Model Poisoning	Manipulated data or model components create hidden or unsafe behavior.	Protect lineage; validate sources; isolate contributions; run anomaly and behavioral tests.
LLM05 — Improper Output Handling	Downstream systems trust model output as safe code, content, or commands.	Treat output as untrusted; validate, encode, parameterize, sandbox, and authorize.
LLM06 — Excessive Agency	An AI system has more tools, permissions, autonomy, or time than needed.	Least privilege; narrow tools; limits; approvals; transaction boundaries; kill switch; audit.
LLM07 — System Prompt Leakage	Hidden instructions or secrets are exposed or relied on as a security boundary.	Keep secrets outside prompts; enforce controls externally; test leakage; limit sensitive context.
LLM08 — Vector and Embedding Weaknesses	Indexes or embeddings allow unauthorized retrieval, poisoning, mixing, or inference.	Tenant isolation; source ACLs; metadata filtering; ingestion review; retrieval tests; deletion.
LLM09 — Misinformation	Confident but incorrect output can lead to harmful decisions or actions.	Ground claims; cite sources; define uncertainty; human review; factual evaluation; safe failure.
LLM10 — Unbounded Consumption	Inputs, loops, output, or tool calls exhaust money, compute, or service capacity.	Rate, token, time, recursion, spend, and concurrency limits; alerts; quotas; circuit breakers.

15.1 How an analyst uses the list

- Confirm the application version and architecture; the base model alone is not the assessment target.
- Map each applicable risk to components, threat scenarios, controls, evidence, test cases, owner, and residual risk.
- Test controls together: filters can be bypassed, and model behavior is probabilistic.
- Validate safe failure, user messaging, detection, response, rollback, and retest.
- Do not label an application ‘OWASP compliant’; OWASP Top 10 is awareness and testing guidance, not a certification standard.

16. Agentic AI Security

Agentic systems add planning, memory, tool selection, delegation, persistence, and real-world authority.



Agent safety depends on constrained authority and verified actions

Figure 6. Constrained agent action loop

Agentic risk theme	Example	Control
Goal manipulation	Untrusted content changes the objective	Trusted goal channel, instruction hierarchy, context separation, confirmation
Tool misuse	Agent calls email, code, payment, admin, or database tool unsafely	Allowlist, schemas, narrow identity, policy enforcement, sandbox
Excessive autonomy	Agent acts without meaningful review	Risk-based approvals, transaction preview, two-person control, stop switch
Memory poisoning	Bad content persists and influences future work	Source trust, scoped memory, validation, expiry, review, deletion
Agent-to-agent trust	One agent treats another's output as authority	Mutual identity, provenance, contracts, validation, least privilege
Runaway behavior	Loops consume time, money, calls, or cause repeated effects	Step/time/cost limits, idempotency, rate controls, circuit breaker
Accountability gap	No person owns a chain of automated decisions	Owner, trace, action receipt, escalation, rollback, incident review

Current source: OWASP released its peer-reviewed Top 10 for Agentic Applications for 2026 on December 9, 2025. Use the official document for its exact risk names and details; apply it with ordinary application, identity, API, data, and transaction security.

17. Retrieval-Augmented Generation Security

RAG can improve grounding, but it adds ingestion, index, retrieval, authorization, citation, and deletion risks.



RAG adds trust boundaries at ingestion, storage, retrieval, and generation

Figure 7. RAG trust boundaries

17.1 RAG controls

- Approve sources, owners, rights, freshness, sensitivity, allowed users, and ingestion method.
- Scan files and content; detect hidden instructions; quarantine and review untrusted contributions.
- Preserve source identity, tenant, classification, ACL, version, date, and deletion status in metadata.
- Enforce authorization before retrieval and again before display; do not rely only on similarity.
- Separate tenants and security domains in storage, keys, indexes, caching, logs, and evaluation.
- Test poisoning, indirect injection, unauthorized retrieval, cross-tenant leakage, stale content, citation accuracy, and deletion.
- Require answers to show useful citations and uncertainty; verify high-impact claims against authoritative sources.
- Propagate source deletion/correction to chunks, vectors, caches, derived stores, and monitoring datasets.

18. Prompt, Interface, and Output Security

Prompts and outputs are application data, not trustworthy control boundaries.

Layer	Control examples
User interface	Purpose, notice, prohibited use, verification duty, safe examples, feedback, appeal
Input	Size/type limits, malware scanning, encoding normalization, classification, redaction, abuse detection
Instructions	Versioned templates, separation of data/instructions, minimal secrets, approval, tests
Model call	Approved model/version, parameters, time/token/rate limits, protected credentials
Output	Schema, allowlist, encoding, parameterization, citation, safety review, confidence/uncertainty
Downstream use	Treat as untrusted; human or policy approval; sandbox; transaction validation; rollback
Logs	Trace IDs and decisions with minimization, access, retention, integrity, and privacy

18.1 Output handling examples

- Never place model output directly into a shell, SQL query, browser DOM, template, access policy, or production code path without purpose-specific validation.
- Use structured schemas but still validate types, lengths, values, authorization, and business rules outside the model.
- Separate content generation from permission to act. A fluent response is not proof of authority or truth.
- Design refusal and error states that do not reveal secrets and that direct users to safe alternatives.

19. Identity, Tools, APIs, and MCP

Identity and tool controls determine the difference between an AI suggestion and an AI-caused event.

Control	Implementation question
Human identity	Is the user authenticated strongly and authorized for the requested data and action?
Workload identity	Does each agent/service have a unique, short-lived, narrowly scoped identity?
Delegation	Can the system prove who delegated what authority, for which resource, purpose, and time?
Tool allowlist	Are tools, methods, parameters, destinations, and data classes explicitly allowed?
Transaction control	Are amount, volume, recipient, environment, and irreversible-action limits enforced outside the model?
Approval	Does the reviewer see the exact proposed action, material context, risk, and change?
Audit	Can each goal, context, model decision, tool call, approval, result, and rollback be reconstructed?

19.1 MCP security

- Model Context Protocol (MCP) connects AI applications to tools and data through standardized interfaces; it does not make a server or tool trusted.
- Inventory servers, owners, code/source, transport, authentication, permissions, tools, schemas, data, network destinations, logs, and update path.
- Use approved registries, verified packages, pinned versions, restricted execution, egress controls, secret isolation, and least-privilege credentials.
- Treat tool descriptions, resources, prompts, and returned content as potentially untrusted and able to influence the model.
- Require authorization at the actual data/action service, not only in the conversational layer.
- Test malicious server behavior, tool-name confusion, parameter injection, cross-server data flow, excessive permissions, and unsafe updates.

20. Privacy, Intellectual Property, and Records

AI data flows raise questions about privacy, confidentiality, intellectual property, recordkeeping, and disclosure.

20.1 Privacy and records assessment

- Identify people, data categories, sensitivity, source, purpose, authority/legal basis, notices, choices, rights, and vulnerable groups.
- Map prompts, uploads, outputs, embeddings, fine-tunes, logs, feedback, human review, training use, providers, subprocessors, locations, and transfers.
- Minimize collection and context; use redaction, pseudonymization, private retrieval, local processing, or synthetic data where appropriate.
- Set retention and deletion by data type and system copy; test rights and deletion through providers, indexes, logs, backups, and derived data.
- Evaluate memorization, inference, re-identification, attribute prediction, membership inference, and cross-user leakage.
- Preserve records needed for decisions, notices, consent/authority, versions, approvals, incidents, disputes, and accountability without retaining everything forever.

20.2 Intellectual property

- Confirm rights and licenses for training, tuning, evaluation, retrieval, prompts, media, code, and outputs.
- Review provider terms for ownership, training use, confidentiality, indemnity, restrictions, and opt-out settings.
- Use provenance and content credentials where appropriate; retain source citations and human contribution records.
- Screen high-risk outputs for copyright-protected material, trademarks, confidential information, open-source license duties, and publicity/personality rights.
- Escalate legal questions; technical similarity tools do not decide infringement.

21. Fairness, Transparency, Explainability, and Human Oversight

Responsible use requires examining unequal effects, meaningful explanations, and real human authority.

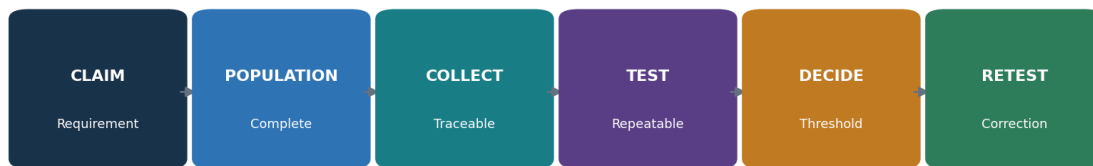
Topic	Practical test
Fairness	Define the relevant harm and groups; compare rates and severity; examine causes, proxies, history, and alternatives
Transparency	Tell the right people AI is used, its purpose, role, limits, data, and how to get help
Explainability	Provide reasons useful to the affected person, operator, reviewer, auditor, or developer
Human oversight	Test reviewer time, competence, information, independence, authority, override, and escalation
Contestability	Provide a usable way to question, correct, appeal, and obtain human review
Accessibility	Test languages, disabilities, literacy, devices, and assistive technology in the real workflow

21.1 Avoid common mistakes

- A fairness metric is not a moral or legal conclusion; different harms may require different measures.
- Removing a protected attribute does not remove proxies or historical patterns.
- An explanation that is technically detailed but unusable to the affected person is not meaningful.
- A human click is not oversight if the reviewer cannot detect error, is overloaded, or cannot disagree.
- Document tradeoffs, affected voices, rejected alternatives, residual uncertainty, and decision authority.

22. Evaluation, Red Teaming, and Acceptance

Evaluation proves defined claims only when the system, data, methods, thresholds, and limitations are traceable.



Assurance joins governance claims to reproducible evidence

Figure 8. Evaluation and evidence chain

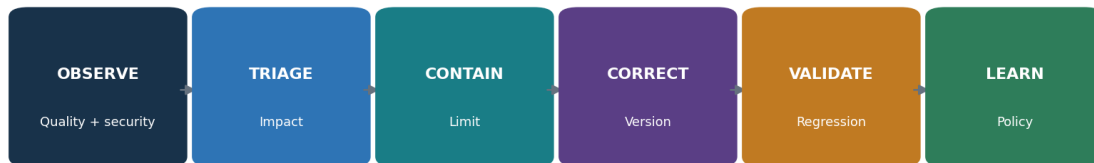
Test type	Examples
Functional	Task completion, accuracy, relevance, groundedness, citation, format
Safety	Harmful content, unsafe advice, escalation, refusal, vulnerable users
Security	Injection, extraction, poisoning, tool abuse, output injection, denial of service
Privacy	PII leakage, memorization, inference, unauthorized retrieval, deletion
Fairness/accessibility	Subgroup errors, language/dialect, disability, proxy effects, usability
Robustness	Noise, paraphrase, adversarial input, long context, dependency failure, drift
Operational	Latency, capacity, rate/cost limits, monitoring, failover, rollback, incident response

22.1 Red-team rules of engagement

- Written authorization, named target, environment, time, people, prohibited actions, data, budget, rate, and stop conditions.
- Synthetic or approved test data; no uncontrolled harmful content, real-person targeting, public scanning, or third-party testing.
- Secure storage for prompts, outputs, vulnerabilities, credentials, and personal information.
- Immediate path for severe findings, accidental exposure, system instability, or safety concern.
- Reproduction, severity rationale, owner, correction, regression test, and closure evidence.

23. Monitoring, Incidents, Change, and Retirement

AI risk changes when data, models, prompts, tools, users, providers, or the outside world change.



Monitoring must lead to human decisions and controlled change

Figure 9. Monitoring and incident loop

Signal	Example response trigger
Quality	Severe-error rate or groundedness falls below approved threshold
Safety	Confirmed harmful output, refusal bypass, or high-impact near miss
Security	Injection success, unauthorized tool call, leakage, abuse, or credential event
Fairness	Material subgroup shift, complaint pattern, or newly affected population
Privacy	Unexpected retention, disclosure, inference, rights failure, or provider-use change
Operations	Cost/latency spike, dependency outage, runaway loop, capacity failure
Change	New model, prompt, data, tool, permission, provider, geography, use, or law

23.1 AI incident response

- Detect and preserve prompts, context, retrieval, model/version, configuration, tools, identities, approvals, outputs, downstream actions, and logs.
- Protect affected people first; stop or limit the system, tools, data, users, transactions, or outputs under approved authority.
- Scope the complete chain and identify repeated decisions or content that require correction, notification, reversal, or human review.
- Coordinate security, safety, privacy, legal, communications, provider, business, and domain response.
- Correct through trusted versions; run regression tests; deploy gradually; watch recurrence.
- Record lessons, accountability, redress, control changes, risk reapproval, and disclosures required by law or contract.

24. Assurance, Evidence, Testing, and Metrics

Assurance connects a requirement to complete scope, reliable evidence, a repeatable test, a conclusion, and retesting.

24.1 Control test method

- State exact criterion, source/version, system/use/version, period, owner, risk, and expected behavior.
- Identify complete populations: use cases, models, users, decisions, prompts, tools, incidents, changes, suppliers, or evaluation cases.
- Reconcile inventory to independent sources such as API billing, code, model registry, identity, procurement, network, or logs.
- Collect source, query, date, permissions, configuration, hash/version, sample, and chain of custody; minimize sensitive evidence.
- Test design and operation; reproduce automated results; validate exceptions and control bypasses.
- Write condition, evidence, population, risk, cause, action, owner, date, interim protection, and retest.

Metric	Definition example
Inventory ownership	Active AI systems with approved owner ÷ active AI systems
Assessment coverage	In-scope systems with current impact/threat/privacy review ÷ in-scope systems
Evaluation pass	Required cases meeting approved thresholds ÷ required cases, with severity and subgroup views
Human override	Eligible decisions reviewed/overridden/escalated with outcomes and reviewer load
Security exposure	Open AI security findings by severity, reachability, age, owner, exception
Incident performance	Detection, containment, correction, redress, recurrence, and overdue actions
Supplier assurance	Critical AI suppliers with current scoped review and closed material gaps ÷ critical suppliers

Dashboard caution: A green percentage can hide missing systems, poor tests, rare severe failures, excluded groups, stale evidence, or accepted risk. Always show population, source, period, threshold, exceptions, uncertainty, and action.

25. CSA AI Controls Matrix v1.1

CSA AICM v1.1 provides a current control matrix for AI governance, security, privacy, operations, and assurance.

25.1 Practical use

- Download the current official AICM v1.1 artifact and record its release, version, license, and any implementation guidance used.
- Define the organization, AI service, life-cycle stage, provider/customer role, technology, data, geography, and control boundary.
- Tailor applicability rather than marking every objective yes; state rationale for not applicable items.
- Map each relevant objective to policy, architecture, process, owner, evidence, test, result, finding, action, and retest.
- Use CSA mappings and STAR for AI materials as aids; verify the exact scope and assurance level of any external claim.
- Do not invent certification or claim compliance based only on a completed questionnaire.

Control theme	Examples of expected evidence
Governance and accountability	AI policy, roles, inventory, risk tiering, training, exceptions, oversight
Data and privacy	Lineage, rights, classification, minimization, quality, access, retention, deletion
Model/system life cycle	Requirements, cards, validation, secure development, versions, approvals, change
Security	Threat model, identity, supplier, testing, logging, incidents, resilience
Responsible AI	Impact assessment, fairness, transparency, human oversight, complaints/redress
Assurance	Control mapping, populations, evidence, independent review, findings, metrics, improvement

26. Open-Source AI Assurance and Security Tools

Open-source tools can improve repeatability, but they do not decide compliance, safety, fairness, or business acceptance.

Tool	Purpose
Garak	LLM vulnerability scanning and probe framework
Promptfoo	Prompt, model, RAG, and red-team evaluation
Giskard	Testing and vulnerability scanning for ML and LLM systems
PyRIT	Risk identification and red-team orchestration for generative AI
Inspect AI	Reproducible AI model evaluations
Adversarial Robustness Toolbox	Adversarial ML attacks and defenses for authorized research
LLM Guard	Input and output scanners for LLM applications
Presidio	Detection and de-identification of personally identifiable information
Guardrails AI	Structured validation and guardrails for model outputs
OpenAI Evals	Open-source framework for model and system evaluation
Langfuse	Open-source LLM tracing, prompt management, and evaluation
MLflow	Experiment tracking, model registry, lineage, and deployment records
Evidently	Data quality, drift, and model monitoring
Deepchecks	Data and model validation for ML and LLM applications
ModelScan	Static scanning of serialized model files
GitLeaks	Secret discovery in source code and history
Trivy	Vulnerability, secret, dependency, image, and configuration scanning
MITRE ATLAS	Knowledge base of adversary tactics and techniques against AI systems

Authorization and safety: Use tools only against systems, models, accounts, repositories, data, and providers you own or are expressly authorized to test. Start with isolated labs and synthetic data. Set request, cost, time, content, and stop limits. Protect credentials, prompts, outputs, and findings.

26.1 Garak

Purpose: LLM vulnerability scanning and probe framework. Official project: [Garak](#)

Safe quick start: Install in an isolated environment; select a lab model and a small approved probe set; protect prompts and outputs; validate results manually.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.2 Promptfoo

Purpose: Prompt, model, RAG, and red-team evaluation. Official project: [Promptfoo](#)

Safe quick start: Create a small YAML test suite with expected behavior; use synthetic data; run locally; review failures; add the suite to version control and CI.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.3 Giskard

Purpose: Testing and vulnerability scanning for ML and LLM systems. Official project: [Giskard](#)

Safe quick start: Connect only an approved test model and dataset; run focused scans; review assumptions and false positives; preserve the report and remediation retest.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.4 PyRIT

Purpose: Risk identification and red-team orchestration for generative AI. Official project: [PyRIT](#)

Safe quick start: Use a lab target and documented rules of engagement; start with harmless objectives; cap requests and cost; review transcripts; never test third parties without permission.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.5 Inspect AI

Purpose: Reproducible AI model evaluations. Official project: [Inspect AI](#)

Safe quick start: Define a task, dataset, solver, and scorer; pin versions; run against an approved model; retain logs, configuration, results, and limitations.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.6 Adversarial Robustness Toolbox

Purpose: Adversarial ML attacks and defenses for authorized research. Official project: [Adversarial Robustness Toolbox](#)

Safe quick start: Use a local toy model and synthetic data; select a single threat; compare baseline and defended results; document applicability and limitations.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.7 LLM Guard

Purpose: Input and output scanners for LLM applications. Official project: [LLM Guard](#)

Safe quick start: Test scanners on synthetic prompts before production; tune thresholds; measure missed and blocked cases; use as one layer, not the only control.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.8 Presidio

Purpose: Detection and de-identification of personally identifiable information. Official project: [Presidio](#)

Safe quick start: Run on synthetic samples; configure recognizers for the data and language; review false positives and misses; protect analyzer output.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.9 Guardrails AI

Purpose: Structured validation and guardrails for model outputs. Official project: [Guardrails AI](#)

Safe quick start: Define an output schema and validators; test valid, invalid, and adversarial cases; fail safely; log validation decisions without exposing sensitive content.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.10 OpenAI Evals

Purpose: Open-source framework for model and system evaluation. Official project: [OpenAI Evals](#)

Safe quick start: Create a small private evaluation set; define measurable criteria; run a baseline and candidate; inspect failures; protect test data and credentials.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.11 Langfuse

Purpose: Open-source LLM tracing, prompt management, and evaluation. Official project: [Langfuse](#)

Safe quick start: Self-host or configure an approved environment; redact sensitive fields; trace a lab workflow; set access and retention; build a small quality dashboard.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.12 MLflow

Purpose: Experiment tracking, model registry, lineage, and deployment records. Official project: [MLflow](#)

Safe quick start: Use a local project; log parameters, dataset reference, metrics, artifacts, owner, and approval; register only a tested model; restrict registry changes.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.13 Evidently

Purpose: Data quality, drift, and model monitoring. Official project: [Evidently](#)

Safe quick start: Create reference and current synthetic datasets; run a report; define action thresholds; investigate drift before retraining or rollback.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.14 Deepchecks

Purpose: Data and model validation for ML and LLM applications. Official project: [Deepchecks](#)

Safe quick start: Run a selected test suite on approved data; review failing checks and relevance; record exceptions; rerun after correction.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.15 ModelScan

Purpose: Static scanning of serialized model files. Official project: [ModelScan](#)

Safe quick start: Scan downloaded model artifacts in quarantine; verify source and hash; investigate warnings; never load an untrusted artifact merely to test it.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.16 Gitleaks

Purpose: Secret discovery in source code and history. Official project: [Gitleaks](#)

Safe quick start: Scan an authorized repository; validate findings; revoke exposed test credentials; remove safely; add prevention; rescan.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.17 Trivy

Purpose: Vulnerability, secret, dependency, image, and configuration scanning. Official project: [Trivy](#)

Safe quick start: Scan an authorized AI service repository or image; validate reachability and context; correct or approve a time-bound exception; rescan.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

26.18 MITRE ATLAS

Purpose: Knowledge base of adversary tactics and techniques against AI systems. Official project: [MITRE ATLAS](#)

Safe quick start: Map a lab architecture to relevant techniques; select mitigations and detections; create a tabletop scenario; do not treat the catalog as a complete checklist.

Retain: written authority, target and version, environment, data, identity/permissions, tool/version/configuration, test cases, thresholds, date, logs, results, analyst validation, limitations, finding, correction, and retest.

27. Manager's AI Governance Playbook

Managers create value by setting decision rights, limiting authority, demanding evidence, and stopping unsafe work.

Manager question	Strong answer	Red flag
Why use AI?	Defined need, benefit, alternative, owner, success and stop measures	Technology looking for a problem
Who can be harmed?	Affected people, severity, likelihood, voice, redress	Only the paying user considered
What can it do?	Documented data, decisions, tools, permissions, limits	Unknown agents, integrations, or shadow use
What proves readiness?	Production-like tests, thresholds, failures, independent challenge	Demo or vendor claim only
Where is the human?	Competent, informed, authorized, measured oversight	Rubber-stamp approval
What changes risk?	Inventory, monitoring, trigger list, regression, rollback	Automatic model updates without review
Who accepts residual risk?	Named authority within appetite, conditions and expiry	Developer accepts business/legal risk alone

27.1 Operating rhythm

- Weekly: severe incidents, active abuse, unauthorized tools/data, critical findings, provider changes, and risk-gate exceptions.
- Monthly: inventory reconciliation, monitoring thresholds, complaints, drift, evaluation failures, tool permissions, spend, and overdue actions.
- Quarterly: portfolio risk, affected groups, supplier concentration, human oversight, red-team themes, legal changes, and retirement candidates.
- At every material change: remap the system, reassess impact/threat/privacy, rerun relevant evaluations, approve, deploy gradually, and retain evidence.

27.2 Questions leaders must answer

- Which AI systems could materially affect people, money, safety, rights, regulated decisions, critical operations, or confidential data?
- What uses are prohibited even if technically possible?
- Can the organization disable tools, stop decisions, notify people, correct records, and recover from a model/provider failure?
- Are incentives rewarding speed or engagement at the expense of safety and truth?
- Can employees raise concerns without retaliation, and are unresolved concerns visible to decision makers?

28. Junior AI Risk and Security Analyst Career Guide

Junior analysts add value by creating accurate inventories, clear system maps, reproducible tests, useful findings, and honest limits.



Junior analysts become job-ready by producing safe, traceable work

Figure 10. Junior AI risk and security pathway

28.1 Entry-level roles

- Junior AI Governance or Responsible AI Analyst
- AI Risk / Model Risk Analyst
- AI Security or GenAI Security Analyst
- GRC / Compliance Analyst with AI focus
- Data Governance or Privacy Analyst
- Third-Party AI Risk Analyst
- AI Evaluation / Trust and Safety Analyst
- Security Assurance Analyst

28.2 Daily work

Discover AI use cases and reconcile inventory across procurement, code, APIs, identity, network, expenses, and interviews.

Document system/data flows, affected people, use limits, suppliers, permissions, and human oversight.

Map NIST, ISO, OWASP, CSA, legal, contractual, and internal requirements to controls and evidence.

Run authorized evaluations and security tests; validate results and protect evidence.

Review provider documentation, terms, model cards, assurance reports, incidents, changes, and customer responsibilities.

Write findings in plain language; assign actions; retest; build metrics with known populations and limitations.

Support AI incident timelines, affected-decision review, corrective action, and lessons learned.

28.3 Resume evidence

- One-page system and data-flow map with trust boundaries.
- AI inventory and risk-tiering method for a fictional company.
- Impact, threat, privacy, and supplier assessments.
- Evaluation plan with acceptance thresholds and reproducible results.
- Three findings with condition, evidence, risk, cause, action, owner, and retest.
- Manager memo explaining go, conditional go, pilot, or no-go decision.
- Sanitized screenshots/configuration only; clearly label work as fictional and educational.

29. Fictional Laboratory, Thirty-Day Plan, and Interviews

A fictional AI application can demonstrate governance, testing, security, and communication without risking real people or systems.

Lab rule: Use local or approved test models, synthetic data, isolated accounts, fixed budgets, and written authorization. Never test a public service, employer, interview company, or third-party model beyond its published program and permission.

29.1 Portfolio lab

- Create a fictional 80-person company building an internal HR policy assistant with RAG. It may explain policy but cannot make employment decisions.
- Write purpose, prohibited uses, affected people, risk tier, RACI, inventory, model/provider choice, and approval gate.
- Create synthetic policy documents, including one malicious indirect-injection file; document provenance, ACLs, ingestion, retention, and deletion.
- Draw data/model/RAG/tool/human trust boundaries and create a MITRE ATLAS/OWASP-based threat model.
- Build evaluation cases for groundedness, citation, privacy, fairness/accessibility, prompt injection, unsafe advice, and unbounded use.
- Use Promptfoo, Garak, Giskard, or Inspect AI in an isolated test; cap activity; validate results manually.
- Correct retrieval ACLs, instruction separation, output validation, least privilege, logging, limits, and escalation; rerun.
- Write an assurance workpaper, three findings, a residual-risk decision, monitoring dashboard, incident tabletop, and retirement checklist.
- Publish only sanitized synthetic evidence and explain what the lab does not prove.

29.2 Thirty-day plan

Days	Focus	Deliverable
1–3	AI basics and trustworthy characteristics	Concept map and glossary
4–6	NIST AI RMF and governance	RACI, policy outline, inventory
7–9	Use-case mapping and impact	System map and impact assessment
10–12	Data/model governance	Dataset and model cards
13–15	Threats, OWASP, ATLAS	Threat model and security requirements
16–18	RAG, agents, identity, MCP	Trust boundaries and tool policy
19–21	Evaluation and red teaming	Test plan, thresholds, results
22–24	Privacy, fairness, transparency	Three review workpapers
25–27	Monitoring, incident, assurance	Dashboard, tabletop, control tests
28–30	Portfolio and interviews	Manager memo and five STAR stories

29.3 What is the NIST AI RMF?

A voluntary framework for managing AI risks through Govern, Map, Measure, and Manage. It focuses on risks to people, organizations, and society.

29.4 Model risk versus system risk?

Model risk concerns model behavior; system risk includes people, data, interfaces, tools, infrastructure, suppliers, processes, and real-world decisions.

29.5 What is prompt injection?

Untrusted content is interpreted as instructions that change behavior or reach data and tools. Treat content as data, constrain authority, validate actions, and test bypasses.

29.6 How do you evaluate an LLM?

Define the use and harms, create representative cases and thresholds, test the complete versioned system, review failures and uncertainty, approve conditions, and monitor change.

29.7 What is RAG?

Retrieval-augmented generation retrieves external content and gives it to a model. It adds source, access, poisoning, injection, citation, freshness, and deletion risks.

29.8 Why is human oversight difficult?

A reviewer may lack time, information, skill, independence, or authority and may trust automation too much. Oversight must be designed and tested.

29.9 What is an AI inventory?

An owned record of use, purpose, people, technology, models, data, suppliers, impact, approvals, controls, monitoring, and retirement.

29.10 How do tools prove compliance?

They do not. Tools produce evidence that an analyst must scope, validate, interpret against requirements, and connect to decisions and remediation.

29.11 How do you report a finding?

State condition, evidence/population, requirement, business and people impact, cause, recommendation, owner, due date, interim protection, and retest.

29.12 What makes a good junior analyst?

Curiosity, careful scope, respect for people and data, reproducible tests, clear writing, honest uncertainty, safe tool use, and follow-through.

30. Templates, Glossary, Index, and References

Reusable forms and authoritative sources help turn concepts into consistent work.

30.1 AI use-case inventory

Field	Entry
System/use ID, status, owner, sponsor	_____
Purpose, benefit, users, affected people	_____
Decisions/content, autonomy, prohibited uses	_____
Model/provider/version/configuration	_____
Data, rights, sensitivity, location, retention	_____
RAG, agents, tools, APIs, MCP	_____
Impact tier, laws/contracts, assessments	_____
Human oversight, appeal, redress	_____
Evaluation, approval, conditions	_____
Monitoring, incidents, changes, retirement	_____

30.2 AI impact and risk assessment

Field	Entry
Context, people, alternatives, dependency	_____
Benefits and success measures	_____
Harms: rights, safety, financial, social, operational	_____
Likelihood, severity, scale, reversibility, uncertainty	_____
Affected groups and accessibility	_____
Data/model/supplier limitations	_____
Controls and evaluation thresholds	_____
Human oversight and contestability	_____
Residual risk and decision authority	_____
Review triggers and expiry	_____

30.3 AI evaluation workpaper

Field	Entry
Claim, risk, requirement, threshold	_____
System/model/prompt/tool versions	_____
Environment and permissions	_____
Dataset provenance and population	_____
Cases, scorers, human rubric, sample	_____
Randomness/repetitions and confidence	_____
Results, failures, subgroup analysis	_____
Limitations and known exclusions	_____
Decision, conditions, findings	_____
Correction and regression retest	_____

30.4 AI incident and change record

Field	Entry
Case/change ID, owner, severity	_____
Affected system/version/people/decisions	_____
Prompt, context, retrieval, tools, identities	_____

Field	Entry
Timeline, evidence preservation, provider	
Containment and affected-person protection	
Correction, reversal, redress, notice	
Root/contributing causes	
Trusted version, validation, rollback	
Risk reapproval and monitoring	
Lessons, actions, retest, closure	

30.5 Glossary

Term	Meaning
Agent	AI-enabled software that plans and uses tools toward a goal.
AI RMF	NIST Artificial Intelligence Risk Management Framework.
AICM	CSA AI Controls Matrix.
Confabulation	Plausible but false or unsupported generated content.
Embedding	Numeric representation used to compare meaning or similarity.
Evaluation	Structured measurement of defined system claims and risks.
Foundation model	Broad model that can be adapted to many downstream tasks.
Groundedness	Degree to which output is supported by provided or authoritative sources.
Human oversight	Meaningful human ability to understand, supervise, intervene, override, or stop.
Impact assessment	Review of intended and foreseeable effects on people and organizations.
Inference	Using a trained model to produce a prediction or output.
MCP	Model Context Protocol, a standard for connecting AI applications to tools and data.
Model card	Structured documentation of intended use, performance, limits, and other facts.
Model drift	Change in performance or behavior as data or context changes.
Prompt injection	Untrusted instructions alter model or application behavior.
RAG	Retrieval-augmented generation.
Red teaming	Authorized adversarial evaluation of risks and failure modes.
Sociotechnical system	Technology and the people, rules, institutions, and context around it.
System card	Documentation of the complete AI system, evaluation, risks, and limits.
Vector database	Store and search service for embeddings and associated metadata.

30.6 Subject index

Subject	Chapter
Agents/autonomy	16, 19
AICM	25
Assurance/evidence	22–25
Data/privacy	11, 20
EU AI Act	2
Fairness/oversight	21
GenAI Profile	8
Inventory/life cycle	10
ISO 42001 / 23894	9
Manager	27
MCP / tools	19
Models/suppliers	12–13
Monitoring/incidents	23
NIST AI RMF	3–7
Open-source tools	26
OWASP / threat model	14–16
RAG	17
Testing / red team	6, 22
Junior analyst	28–29

30.7 Official references

- [NIST AI Risk Management Framework](#)
- [NIST AI RMF 1.0 PDF](#)
- [NIST AI RMF Playbook and AIRC](#)
- [NIST AI 600-1 Generative AI Profile](#)
- [NIST Adversarial Machine Learning Taxonomy](#)
- [ISO/IEC 42001:2023](#)
- [ISO/IEC 23894:2023](#)
- [EU AI Act policy page](#)
- [EU AI Act official implementation timeline](#)
- [OWASP Top 10 for LLM Applications 2025](#)
- [OWASP Top 10 for Agentic Applications 2026](#)
- [OWASP GenAI Security Project](#)
- [MITRE ATLAS](#)
- [CSA AI Controls Matrix resources](#)
- [CSA STAR for AI](#)
- [OECD AI Principles](#)
- [UNESCO Recommendation on the Ethics of AI](#)
- [CISA AI resources](#)
- [UK AI Security Institute Inspect](#)

Final reminder: AI law, standards, threats, model behavior, providers, terms, tools, and official guidance change rapidly. Verify the current source, system version, facts, and jurisdiction before implementation, assessment, deployment, or risk acceptance.